



Actividad 01 · Análisis y planificación del pentest

Elaborado por Ada V.

1. Objetivo del pentest

El objetivo de la prueba de penetración consiste en identificar los riesgos y vulnerabilidades actuales en la aplicación web de Aurora Market. A raíz del error reportado (visibilidad de información de otro usuario), realizar este tipo de evaluación permitirá conocer la naturaleza y el posible impacto de los riesgos. De esta manera, Aurora Market no solo sabrá la condición actual de su infraestructura de seguridad, sino que también podrá utilizar esa información para priorizar las medidas de seguridad a implementar y prevenir consecuencias como la pérdida de confianza de sus usuarios, robo de datos de clientes, así como posibles consecuencias legales.

2. Alcance

Los sistemas y elementos incluidos dentro de la evaluación incluyen:

- La aplicación web
- Mecanismo de autenticación ligado a la web app
- Base de datos ligada a la web app

Aclaración: Tanto el mecanismo de autenticación como la base de datos ligados a la aplicación son componentes de esta, se requieren para el correcto funcionamiento de la misma.

Mientras que los elementos fuera del alcance son:

- Redes sociales
- Correos
- Equipos
- Proveedores
- Otros sistemas

3. Autorización y Condiciones

A continuación, se describen los permisos requeridos:

- Permisos para identificar vulnerabilidades de la aplicación web, incluyendo las conexiones a mecanismos de autenticación y bases de datos (ej.: formularios).

Asimismo, las condiciones acordadas previo a las pruebas son:



- No realizar acciones que interrumpan la operación de la plataforma.
- No realizar acciones que afecten datos reales.
- Cualquier problema detectado deberá ser documentado detalladamente.
- Designar a un punto de contacto de Aurora Market.

4. Tipo de pentest

Se ha seleccionado un pentest tipo black-box. La justificación de esta elección radica en que el equipo de Aurora Market no ha provisto toda la información técnica de su sitio, ni ha brindado credenciales o diagramas de arquitectura; por ende, se tiene información limitada, justo como un atacante externo.

5. Planificación

- **Objetivos**
Dialogar con el equipo de Aurora Market para conocer cuál es el producto final que espera de la evaluación de su aplicación. Acto seguido, definir los objetivos y realizar los ajustes necesarios con el cliente para que quede claramente definido qué es lo que se espera/busca con el pentest.
- **Alcance**
Delimitar qué sí y que no se evaluará en la prueba de penetración. Una vez definido el alcance, este deberá ser confirmado por el cliente.
- **Permisos y Condiciones**
Obtener los permisos necesarios para llevar a cabo las pruebas (indicando para qué se requiere cada uno), y establecer por escrito las condiciones del pentest.
- **Metodología**
Una vez establecido el tipo de pentest, se deberá seleccionar un marco de referencia o guía estándar para definir el “cómo”.
- **Recopilación de Información Previa**
Se implementará el marco de referencia **OSINT** (información de fuentes abiertas/públicas) dado que no se cuenta con credenciales del sistema ni documentación. Es decir, se recurrirá a reunir toda la información pública disponible sobre la aplicación, incluyendo, pero no limitado a: dominio,



subdominios, tecnologías empleadas, registros gubernamentales, directorios en línea.

Esta recopilación contribuirá a la disminución de riesgos de seguridad, además de que permitirá reconocer cómo atacantes podrían utilizarla para técnicas maliciosas como phishing, ingeniería social y exposición de objetivos en ciberataques.

- **Recursos Necesarios**

Se deberá definir la cantidad de personas para la prueba, así como sus perfiles. Dado que actualmente se trata de una plataforma mediana con miles de usuarios, se considera que un equipo de 2 o 3 testers es adecuado.

Respecto a las herramientas a usar, se proponen:

Herramienta	Uso específico
Nmap	Escaneo de puertos abiertos y servicios activos en el servidor donde corre la app web.
Whois	Obtención de información del dominio.
Google Dorks	Descubrimiento de información (archivos, datos personales, vulnerabilidades, entre otros datos) que no aparece con búsquedas convencionales.
Wappalyzer	Fingerprinting/identificación de tecnologías y versiones de software usadas en el sitio web.
OWASP Zed Attack Proxy (ZAP)	Escaneo de vulnerabilidades web, mapeo de la aplicación, pruebas de penetración (ej.: interceptación HTTP).

- **Programación del Pentest**

Para evitar en la mayor medida de lo posible irrupciones en el servicio a los usuarios, el horario propuesto para el pentest es en el rango de 01:00 a 04:00 A.M.

De esta forma se procura trabajar en un momento en el que la tienda en línea tiene menos tráfico de clientes.

6. Fases del pentest

- i. **Reconocimiento**
Recopilar información pública: investigación en motores de búsqueda, subdominios asociados, configuración de DNS, información expuesta



del código fuente del lado del usuario (HTML / JS), metadatos públicos (encabezados, certificados SSL).

ii. Análisis de Vulnerabilidades

Buscar, documentar y analizar vulnerabilidades, teniendo presente el OWASP 10:

- Inyección
- Autenticación interrumpida
- Exposición de datos confidenciales
- Entidades externas XML (XXE)
- Control de acceso roto
- Configuraciones incorrectas de seguridad
- Scripting entre sitios (XSS)
- Deserialización segura
- Registro y monitoreo insuficientes

Para este apartado, se plantea específicamente el uso de **OWASP ZAP**, comenzando con un escaneo automático (dado que se desconoce la arquitectura completa de la app) para luego aplicar el escaneo asistido donde se realicen acciones como:

- Prueba de parámetros en formularios (inyección SQL)
- Inyección de scripts de pruebas en campos de entrada (XSS)
- Revisión de encabezados HTTP mal configurados, verificación de cookies seguras.
- Detección de información sensible transitando sin cifrar.

Esto es complementario a la fase previa, ya que al tener información sobre el stack tecnológico (vía Wappalyzer) es posible establecer pautas para el escaneo, orientándolo a vulnerabilidades conocidas o asociadas a dicho stack/framework. Así, el análisis de vulnerabilidades es dirigido y más eficiente.

iii. Explotación

Se proponen los siguientes métodos:

- Inyección: Donde se pruebe una consulta simple para confirmar el acceso, sin extraer datos de clientes.
- Autenticación interrumpida: Probar ataques de fuerza bruta controlados en cuentas de prueba, no de clientes reales



- XSS: Inyectar un script de prueba inofensivo para confirmar su ejecución
- iv. Post-Explotación
Con base en los métodos descritos anteriormente, lo que se evaluaría como impacto es lo siguiente:
 - ¿Qué tanto de la base de datos queda expuesto?
 - Si una cuenta está comprometida, ¿a qué información y/o funciones se puede acceder?
 - Evaluar si el script tendría la capacidad de usarse para robar sesiones de usuarios reales.
- v. Informe
Redactar el informe ejecutivo para resumir los hallazgos, indicar el impacto comercial y las recomendaciones; en este caso, el público objetivo son los ejecutivos de la empresa.

Asimismo, escribir el informe técnico orientado al equipo de TI de Aurora Market para describir las vulnerabilidades, documentar las pruebas realizadas con su evidencia, describir el impacto técnico y plasmar las recomendaciones con detalle.

7. Investigación

Ahora bien, la metodología elegida es **OWASP**, considerando OWASP Top 10 y el marco de referencia Web Security Testing Guide (WSTG).

Se considera que sería útil para este proyecto porque el primero enlista las vulnerabilidades y riesgos de ciberseguridad actualizados en aplicaciones web; mientras que el segundo recurso permite que se implementen las mejores prácticas, como técnicas y tareas para cada etapa del pentest.